AI DATA EXPOSURE REGISTER

Riverside Family Practice

AI Tool Inventory, BAA/DPA Matrix, Acceptable Use Policy & 90-Day Remediation Plan

Practice profile: 12-physician family medicine group, Tennessee
Prepared: October 28, 2026
Method: Staff survey (17 respondents) + Google Workspace & M365 admin console OAuth review
Document support: Sui-Generis — AI Data Exposure Register

Executive Summary

A survey of Riverside's 12 physicians and 5 administrative staff, cross-referenced against OAuth-connected third-party applications in the practice's Google Workspace and Microsoft 365 admin consoles, identified **14 distinct AI tools** in active use. Three are approved, tenant-governed tools with executed BAAs and DPAs. Two are in use under a restriction (no PHI permitted). The remaining nine are either unapproved consumer-tier tools in active use by clinical or administrative staff, or approved vendors being used at the wrong tier without the required agreements in place.

Two tools — **Otter.ai** and **Fireflies.ai** — are currently being used to record and transcribe live patient conversations and clinical case discussions without a Business Associate Agreement. **Zoom AI Companion** is auto-generating telehealth visit summaries under the same condition. These three represent the highest-priority items in the remediation plan below.

14	3	2	2	7
AI TOOLS IDENTIFIED	APPROVED	RESTRICTED (NON-PHI)	PENDING / WRONG TIER	UNAPPROVED

This register documents current-state AI tool usage and associated data-handling terms as disclosed by vendor documentation and staff reporting as of the date above. It is a technical work product; it does not constitute a legal determination of HIPAA compliance or a legal opinion, and should be reviewed by the practice's legal counsel before reliance.

1. AI Tool Inventory

Identified via staff survey (17 respondents, administered October 28, 2026) and OAuth-connected app review in Google Workspace and Microsoft 365 admin consoles.

TOOL	TIER IN USE	USERS	PRIMARY USE AT RIVERSIDE	STATUS
ChatGPT (Free / Plus) OpenAI	Consumer (Free/Plus)	6 of 12 providers	Drafting patient instructions, visit summaries, and appeal letters	Unapproved — Shadow IT
ChatGPT Team OpenAI	Team	Office manager	Drafting billing correspondence referencing patient accounts	Unapproved — Shadow IT
Microsoft 365 Copilot Microsoft	Microsoft 365 Business Premium (tenant-wide)	All front-office staff (5)	Drafting scheduling correspondence and internal memos within M365 apps	Approved
Google Gemini (Workspace) Google	Google Workspace Business Standard (tenant-wide)	3 administrative staff	Drafting patient-facing emails and internal documentation	Approved
Google Gemini (personal app) Google	Consumer (personal Google account)	2 providers (personal phones)	Ad hoc clinical question look-ups, occasionally pasting case details	Unapproved — Shadow IT
Otter.ai Otter.ai, Inc.	Free / Basic	2 providers	Transcribing patient phone calls and in-office consultations	Unapproved — Shadow IT
Grammarly Grammarly, Inc.	Business	4 administrative staff	Grammar/tone checking on general correspondence	Approved — Non-PHI Only
Claude.ai (Free) Anthropic	Consumer (Free)	Billing coordinator	Drafting insurance appeal letters referencing patient diagnoses	Unapproved — Shadow IT

Perplexity Perplexity AI, Inc.	Free	1 provider	General medical reference look-ups	Unapproved — Shadow IT
DeepL DeepL SE	Free	Front desk (2 staff)	Translating patient instructions and intake forms into Spanish	Pending / Wrong Tier
Fireflies.ai Fireflies.ai, Inc.	Free	3 providers (clinical staff meetings)	Transcribing weekly provider huddles that include patient case discussion	Unapproved — Shadow IT
Dragon Medical One Nuance / Microsoft	Enterprise (cloud, healthcare-specific)	All 12 physicians	Clinical dictation directly into the EHR	Approved
Canva Canva Pty Ltd	Free	Office manager	Designing patient education handouts and waiting-room signage	Approved — Non-PHI Only
Zoom AI Companion Zoom Communications, Inc.	Zoom Business (AI Companion enabled tenant-wide)	6 providers (telehealth visits)	Auto-generating visit summaries and transcripts during telehealth appointments	Pending / Wrong Tier

2. BAA / DPA Matrix

Per-tool data-handling terms. "Trains on Input" reflects the vendor's policy for the tier actually in use at Riverside, which may differ from the vendor's enterprise-tier policy.

● Yes● No● Partial / conditional* Zoom offers a BAA addendum covering AI Companion for qualifying healthcare accounts; Riverside has not yet executed it.

TOOL	VENDOR TIER	TRAINS ON INPUT	BAA AVAILABLE	DPA IN PLACE	APPROVED FOR PHI	RISK NOTE
ChatGPT (Free / Plus)	Consumer (Free/Plus)	Y	N	N	N	High — consumer tier trains on input by default and offers no BAA; PHI has been entered in session prompts.
ChatGPT Team	Team	N	N	N	N	High — training is off by default on Team, but OpenAI does not offer a signable BAA on this tier; no DPA executed.
Microsoft 365 Copilot	Microsoft 365 Business Premium (tenant-wide)	N	Y	Y	Y	Low — covered under the practice's executed Microsoft BAA and Online Services Terms; data stays within tenant boundary.
Google Gemini (Workspace)	Google Workspace Business Standard (tenant-wide)	N	Y	Y	Y	Low — Workspace core service; BAA and DPA executed with Google; content excluded from model training per Workspace terms.
Google Gemini (personal app)	Consumer (personal Google account)	Y	N	N	N	High — personal consumer account, outside tenant BAA coverage; used on personal devices outside MDM.
Otter.ai	Free / Basic	Y	N	N	N	High — live transcription of patient conversations with no BAA; free tier retains and may use audio/text for training.
Grammarly	Business	N	N	Y	N	Medium — Business tier excludes content from training and offers a DPA, but Grammarly does not offer a BAA; must remain PHI-free.
Claude.ai (Free)	Consumer (Free)	Y	N	N	N	High — free consumer tier, no BAA; PHI-containing appeal drafts have been entered in prompts.
Perplexity	Free	Y	N	N	N	Medium — no PHI confirmed entered

						to date, but tool is unapproved and unmonitored; free tier trains on input.
DeepL	Free	Y	N	N	N	Medium-High — free tier retains/trains on submitted text, which includes patient names and clinical instructions; a Pro/API tier with a DPA is available and has not been adopted.
Fireflies.ai	Free	Y	N	N	N	High — automatic meeting transcription and storage of clinical case discussions with no BAA.
Dragon Medical One	Enterprise (cloud, healthcare-specific)	N	Y	Y	Y	Low — purpose-built healthcare dictation platform; BAA executed with Nuance/Microsoft; long-standing approved tool.
Canva	Free	N	N	N	Restricted	Low, conditional — approved for non-PHI design work only; no BAA exists, so no patient identifiers may ever be entered.
Zoom AI Companion	Zoom Business (AI Companion enabled tenant-wide)	N	Y*	Y	N	High — Zoom offers a BAA covering AI Companion for qualifying healthcare accounts, but the practice has not executed the healthcare BAA addendum; feature is actively summarizing PHI-containing visits today.

3. Acceptable Use Policy — Template

Drafted for adoption by Riverside leadership; placeholders in highlight require practice-specific input before distribution. Final policy should be reviewed by the practice's legal counsel.

Artificial Intelligence Acceptable Use Policy

Practice: [PRACTICE LEGAL NAME] **Effective date:** [EFFECTIVE DATE] **Policy owner:** [NAME / TITLE, e.g., Practice Manager]
Review cycle: [ANNUALLY / SEMI-ANNUALLY], next review [REVIEW DATE]

1. Purpose

This policy governs the use of artificial intelligence (AI) tools, including generative AI chatbots, transcription services, and AI-enabled features within approved software, by all employees, contractors, and affiliated providers of [PRACTICE NAME]. Its purpose is to prevent unauthorized disclosure of protected health information (PHI) and to establish a clear, auditable process for evaluating and approving new AI tools.

2. Approved Tools

Only tools listed on the current Approved AI Tool List may be used for any task involving patient information. As of [EFFECTIVE DATE], the Approved AI Tool List consists of:

- [Microsoft 365 Copilot — tenant license, scheduling and internal correspondence]
- [Google Gemini (Workspace) — tenant license, patient-facing email drafting]
- [Dragon Medical One — clinical dictation into the EHR]

Tools marked "Restricted" may be used only for the specific non-PHI purpose documented in the current AI Data Exposure Register (e.g., [Canva for patient-education design work, with no patient identifiers entered]). No other AI tool may be used for any work purpose unless formally approved under Section 4.

3. Prohibited Conduct

- Entering any patient name, date of birth, medical record number, diagnosis, treatment detail, photograph, or other PHI into any AI tool not on the Approved AI Tool List.
- Using a personal (non-practice-issued) account to access any AI tool for a work purpose.
- Recording or transcribing any patient conversation, visit, or clinical discussion using a tool without an executed BAA.

- Installing or enabling browser extensions, add-ins, or AI features in approved software without prior written approval.

4. Requesting a New Tool

Employees who wish to use an AI tool not on the Approved AI Tool List must submit a request to [POLICY OWNER] describing the intended use, the data involved, and the vendor. No tool may be used for PHI-related work until it has a reviewed BAA (where PHI is involved), a signed DPA, and has been added to the Approved AI Tool List in writing.

5. Training & Acknowledgment

All employees and providers must complete AI acceptable use training within 30 days of hire and upon any material policy update, and must sign the acknowledgment below.

6. Enforcement

Violations of this policy will be addressed under [PRACTICE NAME]'s standard HR disciplinary process and, where applicable, reported under the practice's HIPAA breach notification procedure.

Employee signature Date: [DATE]

Print name

4. 90-Day Remediation Plan

Four two-to-four-week phases from October 28, 2026 to January 26, 2027, ordered by risk. Each item names a specific action (block, restrict, upgrade, replace, or decommission) and an owner-ready deadline.

Phase 1 — Immediate Containment

Oct 28 – November 11, 2026 · due **November 11, 2026**

ACTION	TOOL / ITEM	DETAIL
Block	**ChatGPT (Free/Plus)**	Block at network/DNS level for office devices; issue written notice to the 6 identified users; no PHI is to be entered into any consumer AI tool effective immediately.
Block	**Claude.ai (Free)**	Block access on office devices; billing coordinator redirected to use only Microsoft 365 Copilot for correspondence drafting.
Block	**Otter.ai**	Discontinue use for any patient call or visit recording effective immediately; existing recordings/transcripts inventoried for retention review.
Block	**Fireflies.ai**	Disable Fireflies bot from provider meeting calendar invites; existing meeting transcripts exported and then deleted from Fireflies per data deletion request.
Block	**Google Gemini (personal app)**	Issue written notice to the 2 providers; personal-account AI use for any work purpose prohibited under interim policy pending MDM review.
Issue	**Interim Acceptable Use Notice**	Distribute the interim AI Acceptable Use Policy (see template below) to all staff for signature within 5 business days.

Phase 2 — Tier Correction & Vendor Agreements

November 12, 2026 – November 27, 2026 · due **November 27, 2026**

ACTION	TOOL / ITEM	DETAIL
Decide & Execute	**Zoom AI Companion**	Practice manager to execute Zoom's healthcare BAA addendum covering AI Companion, or disable AI Companion tenant-wide if the addendum is not completed by the deadline.
Decommission / Upgrade	**ChatGPT Team**	Either decommission in favor of Microsoft 365 Copilot (already approved and BAA-covered), or evaluate ChatGPT Enterprise with a signed data processing agreement — decision owned by practice manager.
Restrict	**Canva**	Publish written restriction: design work only, no patient names, photos, or identifiers of any kind; office manager to confirm no historical PHI exists in existing designs.
Restrict	**Grammarly**	Confirm Business-tier training-exclusion setting is active for all 4 seats; publish written restriction prohibiting PHI in any text checked through Grammarly.

Phase 3 — Upgrade & Replace

November 28, 2026 – December 27, 2026 · due **December 27, 2026**

ACTION	TOOL / ITEM	DETAIL
Upgrade	**DeepL**	Upgrade front desk to DeepL Pro (API/CAT tier) with a signed DPA and training opt-out confirmed; free-tier access removed from office devices.
Replace	**Perplexity**	Discontinue informal use; if clinical reference lookup is a recurring need, evaluate a vetted, BAA-eligible clinical reference tool through the practice's EHR vendor.
Train	**All staff**	Conduct a mandatory 45-minute AI tool training session covering the approved tool list, the Acceptable Use Policy, and how to request evaluation of a new tool.
Finalize	**Acceptable Use Policy**	Collect signed acknowledgment from all 12 physicians and all administrative staff; file signed copies in HR records.

Phase 4 — Verification & Cadence

December 28, 2026 – January 26, 2027 · due **January 26, 2027**

ACTION	TOOL / ITEM	DETAIL
Audit	**Google Workspace / M365 admin consoles**	Re-pull OAuth-connected third-party app list from both admin consoles and reconcile against this register to confirm no new unapproved tools have appeared.
Re-survey	**All staff**	Issue a short follow-up survey confirming discontinued use of blocked tools and capturing any newly adopted tools.
Sign off	**Practice manager**	Practice manager reviews and signs off on remediation completion for each item in this plan; exceptions documented with a revised target date.
Schedule	**Annual re-inventory**	Calendar the next full AI Data Exposure Register re-inventory for October 28, 2027 (annual cadence).